Natalyx MVP Fixes

Work Package 09: Documents, active case, and provider handoffs

L. Rhodes (plan owner) - A. Zhao (technical feedback reconciled)

2026-07-12

Contents

1 Work Package 09: Documents, active case, and provider handoffs **2**

1.1 Purpose and outcome 2

1.2 Verified current-state evidence 3

1.3 Architecture and contracts 4

1.4 Explicit PR sequence 11

1.5 Cross-repository coordination 29

1.6 Test and acceptance matrix 29

1.7 Risks and decisions 30

1.8 Existing-work salvage 36

1.9 Ownership recommendation 39

1.10 Definition of done 41

1 Work Package 09: Documents, active case, and provider handoffs

Review draft only. Ownership and sequencing remain recommendations until Luke and Alan approve the plan together.

Plan	Value
Work package	WP09
Plan file	`WP09 - Documents, active case, and provider handoffs.md`
Proposed PRs	P09-01, P09-02, P09-03, P09-04, P09-05, P09-06
Inspection snapshot	2026-07-12 19:30 America/New_York

1.1 Purpose and outcome

Problem. Current documents are metadata-only; the dirty provider branch is unreviewed and can over-project facts. There is no durable private S3/KMS/quarantine/recovery pipeline.

Why this package exists. It creates a reviewable boundary so the programme can progress without mixing product, data, security, infrastructure and rollout concerns in one oversized change.

Completed outcome. A metadata-only requirement/work-item lifecycle distinct from the secure document-content lifecycle, resilient storage/scan/download, usable active-case surfaces, and consent-scoped immutable provider snapshots with operational review.

Explicit non-goals.

- No ambient provider case access
- No clinical approval by Natalyx
- No direct public objects
- No automatic promotion of AI/IP assertions

1.2 Verified current-state evidence

Classification is explicit: **verified** is observed code/PR/live behavior; **verified limitation** records an evidence gap; **design authority** is an approved planning source; **design decision** is proposed future behavior. None is silently treated as another.

ID	Class	Repository / ref	File, construct or location	Finding
E-006	verified	app / PR #122@e853821	PR comment Review round 2 addressed and changed workflow/tests	Updated PR #122 reports 499 tests plus return_to, TTL, CAS, self-invite, lens and Learn fail-closed fixes; green checks were observed. These are salvage candidates, not blanket merge approval.
E-012	verified	app / PR #122@e853821	app/storage/invitations.py and PR review-round comment	The updated case invitation work adds 14-day ceiling, CAS transitions, mismatch confirmation, self-invite refusal, return_to preservation and paired lens tests; it has no Node 0 workspace target.
E-018	verified	app / PR #124@84a5a84	app/storage/documents.py:1-114; app/storage/schema.py:785-801	Documents are explicitly metadata-only; storage_uri/checksum fields exist but no durable upload, quarantine, scan, authorization-by-purpose, retention or recovery pipeline.
E-019	verified protected work	app / dirty feature/provider-exchange-layer-v0@84a5a84	app/provider_handoffs.py:109-133 and uncommitted handoff modules	The protected provider work is not a PR. Its broad GC-owner fact selection can include private/provisional data, so only selective port after provenance/purpose review is safe.
E-028	verified review	app / PR #124 comment 4948149089	Consolidated review - findings for the WP00 extraction ledger	Alan's completed review classifies #124 as high-value extraction material rather than a merge unit and identifies transaction, privacy, scoring, access, validation, invariant, exposure, retention, performance, CSS and CI findings.

ID	Class	Repository / ref	File, construct or location	Finding
E-029	verified preserved branch	app / feat/byos-journey-wave-2@5b63e3a7	exact three-commit stack on e853821	Wave 2 contains phase-1 cluster pages, metadata-only request/review, case anchoring and role/owner fixes. Controlled local evidence passed 535 tests with 9 skipped and 36/36 focused tests, but no branch checks, PostgreSQL, browser/accessibility or visual run exists.
E-030	independently reproduced defect	app / feat/byos-journey-wave-2@5b63e3a7	app/storage/schema.py orphan cleanup; document review CAS/work-item payload	A second init_db deletes canonical case-anchored reviewer work because participant_id is empty. Separately, a stale v1 work item can approve v2 after same-row resubmission because it is not bound to an immutable submission revision.
E-031	verified	app / feat/byos-journey-wave-2@5b63e3a7	case_members.py, case_documents.py, storage/documents.py, routes/agency.py	Membership roles still conflate participation, lens and access; document/reviewer loaders are broad or global; participant role/lens can be caller-supplied; operator actions lack a canonical organization-scoped staff capability; no RLS/non-owner runtime enforces denial.

1.3 Architecture and contracts

- A requirement, readiness marker or review work item is not a document and cannot be approved as if content exists.
- Private bucket, block-public-access, KMS, opaque keys, application authorization, size/type/checksum gates, quarantine/scan, audit, retention, and orphan cleanup are mandatory for content.
- Provider handoffs are purpose-bound snapshots with checksum/revision/expiry and consent; provider-visible items are allowlisted, not inferred from broad visibility.
- ECS replacement must not lose upload/task state; recovery resumes from durable metadata and object state.

Contract area	Package rule
Ownership boundary	`app`, `infra`; repository-specific PRs remain separate.
Entities/state	`case`, `case_invitation`, `document + document_version + upload`
Authorization	Authenticated subject/service plus entity membership, role, purpose, consent and expected revision; query parameters, links and UI state are never authority.

Contract area	Package rule
API/service	Intent/finalize/status/download/replace/delete commands. Participant document commands join requirement IDs to immutable content versions.
Storage	Versioned document/upload/scan/object metadata. Requirement submissions and durable typed work items use constrained case/org/owner anchors and immutable expected revisions. Handoff/packet/snapshot/transmission/evidence ledgers under migrations.
Audit	Use the common transition envelope and append-only source/event identifiers; redact tokens, raw documents, prompts and sensitive payloads.
Failure	Fail closed for authorization, provenance, money, document and PHI boundaries; expose a bounded actionable error and preserve retry/repair evidence.
Observability	Correlation, policy/schema/config version, transition and dependency result metrics without PHI/PII payload logging.
Compatibility	Additive/dual-compatible changes, explicit version pins, old/new revision window and named forward repair.
Privacy/PHI	Synthetic only through A2; approved PII only at B1; PHI remains blocked until formal B2.

1.3.1 Applicable state machines

1.3.2 Paid case lifecycle (`case`)

Owner: **natalyx-app**. States: `enrollment_pending`, `active`, `paused`, `closed`, `cancelled`.

Transition: `none` -> `enrollment_pending`

- **Actor:** promotion service
- **Evidence:** byos.workspace_promotion_authorized.v1 + projection manifest
- **Idempotency key:** `promotion:{commitment}:v1`
- **Invalid transitions:** No authorization/duplicate workspace
- **Audit event:** `paid_case_created`
- **Retry:** Return same case
- **Recovery:** Forward-repair same promotion

Transition: `enrollment_pending` -> `active`

- **Actor:** authorized coordinator/domain service
- **Evidence:** approved onboarding/compatibility/intake/education evidence
- **Idempotency key:** `case:{id}:activate:{evidence_hash}`
- **Invalid transitions:** Missing/revoked evidence or GC consent
- **Audit event:** `case_activated`
- **Retry:** No duplicate activation/invoice

- **Recovery:** Return pending with unmet checklist

Transition: `active -> paused`

- **Actor:** authorized commercial/operations policy
- **Evidence:** audited non-critical pause reason
- **Idempotency key:** `case:{id}:pause:{event}`
- **Invalid transitions:** Safety-critical access cannot be paused
- **Audit event:** `case_paused`
- **Retry:** Idempotent
- **Recovery:** Resume after evidence; preserve entitled docs

Transition: `paused -> active`

- **Actor:** authorized operator/domain service
- **Evidence:** pause reason resolved
- **Idempotency key:** `case:{id}:resume:{event}`
- **Invalid transitions:** Unresolved safety/authorization block
- **Audit event:** `case_resumed`
- **Retry:** Idempotent
- **Recovery:** Escalate manual review

Transition: `active|paused -> closed`

- **Actor:** authorized coordinator
- **Evidence:** birth/close or completed termination handoff evidence
- **Idempotency key:** `case:{id}:close:{evidence_hash}`
- **Invalid transitions:** Open critical obligations
- **Audit event:** `case_closed`
- **Retry:** No-op if same evidence
- **Recovery:** Reopen only by exceptional audited event

Transition: `enrollment_pending|active|paused -> cancelled`

- **Actor:** authorized operator under policy
- **Evidence:** withdrawal/non-clearance/cancellation + financial disposition
- **Idempotency key:** `case:{id}:cancel:{request}`
- **Invalid transitions:** Cannot erase records/refund ledger
- **Audit event:** `case_cancelled`
- **Retry:** Idempotent
- **Recovery:** Replacement is a new case/workspace policy event

1.3.3 Paid-case membership invitation (`case_invitation`)

Owner: **natalyx-app**. States: `issued`, `pending_identity`, `identity_bound`, `mismatch_pending`, `issuer_confirmed`, `consented`, `redeemed`, `declined`, `revoked`, `expired`, `superseded`.

Transition: `none -> issued`

- **Actor:** authorized IP case member
- **Evidence:** enrollment_pending/active case + recipient binding
- **Idempotency key:** `case-invite:{case}:{role}:{generation}`
- **Invalid transitions:** Self/member/active-GC/unauthorized
- **Audit event:** `case_invite_issued`
- **Retry:** Return current; supersede prior live GC invite
- **Recovery:** Issue corrected invite

Transition: `issued` -> `pending_identity`

- **Actor:** recipient
- **Evidence:** valid addressed token landing
- **Idempotency key:** `case-invite:{id}:land`
- **Invalid transitions:** Expired/revoked
- **Audit event:** `case_invite_opened`
- **Retry:** Safe repeat
- **Recovery:** Authenticate with return_to

Transition: `pending_identity` -> `identity_bound|mismatch_pending`

- **Actor:** auth provider
- **Evidence:** verified subject/email
- **Idempotency key:** `case-invite:{id}:bind:{subject}`
- **Invalid transitions:** Terminal/duplicate/different subject
- **Audit event:** `case_invite_bound|mismatch`
- **Retry:** CAS protects terminal
- **Recovery:** Issuer confirmation or corrected invite

Transition: `mismatch_pending` -> `issuer_confirmed`

- **Actor:** authorized issuer
- **Evidence:** explicit reviewed mismatch confirmation
- **Idempotency key:** `case-invite:{id}:confirm:{issuer}`
- **Invalid transitions:** Issuer unauthorized/recipient changed
- **Audit event:** `case_invite_mismatch_confirmed`
- **Retry:** CAS no-op
- **Recovery:** Revoke and reissue

Transition: `identity_bound|issuer_confirmed` -> `consented`

- **Actor:** invitee
- **Evidence:** paid-case role/privacy consent version
- **Idempotency key:** `case-invite:{id}:consent:{version}`
- **Invalid transitions:** Stale/missing consent
- **Audit event:** `case_invite_consented`
- **Retry:** Idempotent
- **Recovery:** Present current consent

Transition: `consented -> redeemed`

- **Actor:** invitation service
- **Evidence:** single transaction creates person/party/membership
- **Idempotency key:** `case-invite:{id}:redeem`
- **Invalid transitions:** Existing member/active GC/expired/revoked
- **Audit event:** `case_invite_redeemed`
- **Retry:** Return same membership
- **Recovery:** Rollback entire transaction; forward repair from invite

Transition: `issued|pending_identity|identity_bound|mismatch_pending|issuer_confirmed|consented -> declined|revoked|expired|superseded`

- **Actor:** invitee/issuer/system
- **Evidence:** explicit decline/revoke/TTL/new generation
- **Idempotency key:** `case-invite:{id}:terminal:{event}`
- **Invalid transitions:** No terminal overwrite
- **Audit event:** `case_invite_terminal`
- **Retry:** Idempotent CAS
- **Recovery:** Fresh invitation only

1.3.4 Document lifecycle (`document + document_version + upload`)

Owner: **natalyx-app; storage in natalyx-infra**. States: `upload_requested`, `uploading`, `quarantined`, `scanning`, `available`, `review`, `approved`, `replaced`, `deleted`, `failed`.

Transition: `none -> upload_requested`

- **Actor:** authorized case member
- **Evidence:** document purpose/type/size intent
- **Idempotency key:** `upload:{case}:{client_request}`
- **Invalid transitions:** Unauthorized/type/size/retention block
- **Audit event:** `upload_requested`
- **Retry:** Return same intent
- **Recovery:** Expire/orphan intent

Transition: `upload_requested -> uploading`

- **Actor:** client/storage service
- **Evidence:** authorized upload starts
- **Idempotency key:** `upload:{id}:start`
- **Invalid transitions:** Expired intent/wrong key
- **Audit event:** `upload_started`
- **Retry:** Multipart resume
- **Recovery:** Abort and mark failed/orphan cleanup

Transition: `uploading -> quarantined`

- **Actor:** finalize service
- **Evidence:** object exists + size/checksum/content sniff
- **Idempotency key:** `upload:{id}:finalize:{checksum}`
- **Invalid transitions:** Mismatch/missing object
- **Audit event:** `upload_quarantined`
- **Retry:** Repeat verify
- **Recovery:** Delete bad object; request new upload

Transition: `quarantined -> scanning`

- **Actor:** scan worker
- **Evidence:** durable queued task
- **Idempotency key:** `scan:{version}:{engine_version}`
- **Invalid transitions:** Already available/deleted
- **Audit event:** `scan_started`
- **Retry:** Leased retry
- **Recovery:** Lease expiry requeues after ECS replacement

Transition: `scanning -> available|failed`

- **Actor:** scan service
- **Evidence:** signed clean/malicious/error result
- **Idempotency key:** `scan:{version}:{result_id}`
- **Invalid transitions:** Unknown result/engine
- **Audit event:** `scan_completed|scan_failed`
- **Retry:** Inbox replay no-op
- **Recovery:** Remain quarantined on timeout/error; security review

Transition: `available -> review|approved`

- **Actor:** authorized participant/reviewer
- **Evidence:** purpose-specific review/evidence
- **Idempotency key:** `document:{version}:review:{event}`
- **Invalid transitions:** Wrong role/stale version
- **Audit event:** `document_reviewed`
- **Retry:** Idempotent
- **Recovery:** New review revision

Transition: `available|review|approved -> replaced`

- **Actor:** authorized owner
- **Evidence:** new clean version linked
- **Idempotency key:** `document:{id}:replace:{new_version}`
- **Invalid transitions:** New version not available
- **Audit event:** `document_replaced`
- **Retry:** Return current version
- **Recovery:** Keep prior per retention; roll current pointer forward

Transition: `available|review|approved|replaced|failed -> deleted`

- **Actor:** authorized policy job/operator
- **Evidence:** retention/delete request and no hold
- **Idempotency key:** `document:{version}:delete:{request}`
- **Invalid transitions:** Legal hold/provider obligation
- **Audit event:** `document_deleted`
- **Retry:** Tombstone idempotent
- **Recovery:** Object-delete retry/orphan alarm; metadata/audit retained

1.3.5 Data authorship/provenance rules

- Every assertion/revision records subject_ref, semantic_key, author_subject/person/role, authorship_class, provenance, verification_status, visibility, purpose, source_ref, derived_from, supersedes_id, promotion_event_id, policy version and immutable timestamps.
- Class 1 defaults IP-private; class 2 defaults IP-private/internal and visibly says reported by the intended parent, not confirmed by the GC.
- Class 3 is GC-authored and shared only per field/purpose; class 4 is GC-only private; class 5 requires an evidence-linked role-gated reviewer/provider rail.
- GC confirmation appends a class-3 revision referencing the class-2 assertion. Relationship answers can coexist; disagreement is not an overwrite.
- Unselected candidates, raw health assertions, ranking scores and private IP notes do not promote. Derived values inherit the weakest source status.
- Copying, promotion, generic proposal approval, IP assertion or AI inference can never create Natalyx-reviewed, provider-confirmed, medically cleared, legally cleared or insurance-verified truth.

1.3.6 Durable document and S3 contract

1.3.6.1 Metadata

- Requirement/readiness submissions and reviewer work items are separate entities from document versions and objects.
- A metadata-only marker cannot carry file bytes/storage_uri, enter document-approved state or claim that a clinic received/reviewed content.
- Work items bind organization, case, requirement, owner scope and immutable submission revision; decision plus audit is atomic and completion is durable/idempotent.
- Free text is minimum-necessary and strictly bounded; sensitive categories remain synthetic through A2 and content/PHI paths remain disabled until their gates.

1.3.6.2 Storage

- Private versioned quarantine bucket and clean vault with block-public-access, SSL-only and KMS encryption.
- App can create short-lived unique upload targets in quarantine but cannot read unscanned content; scanner moves/copies only clean versions to vault.

- Object key: env/{org_id}/{case_id}/{document_id}/{version_id}/{generated_object_id}; no names, emails, filenames or clinical labels.
- Authorization is always a PostgreSQL access-grant/ownership/purpose/consent decision independent of the key; participation or presentation lens alone is insufficient.
- CloudTrail S3 data events and app document_access_event records provide purpose-aware access evidence.

1.3.6.3 Upload

- Configurable maximum size; provisional 25 MiB awaits D-DOC-02.
- Initial proposed allowlist PDF/JPEG/PNG; DOCX only after scanner/archive review; no macro-enabled Office formats.
- Unicode-normalize/sanitize display filename; byte-sniff MIME, expected length and required SHA-256 checksum.
- Never reuse a key. Finalize verifies object version, HeadObject size/checksum/type and upload-session ownership.
- S3 event -> durable queue -> scanner -> signed clean/rejected/error result; unavailable/timed-out scan remains quarantined.

1.3.6.4 Download

- App authenticates and authorizes exact version/purpose, records access event, then returns a very short-lived clean-vault GET with safe content disposition.
- App proxy is reserved for justified transformation/audit cases, not the default durable path.

1.3.6.5 Recovery

- Upload sessions/tasks live in Postgres/queue so ECS replacement does not lose them; leases expire and retry idempotently.
- Replacement creates a new immutable version and supersedes the prior current pointer.
- Deletion is an audited tombstone followed by retention/legal-hold controlled purge; object-delete failures alert and retry.
- Orphan reconciliation handles expired intents and objects without document versions; lifecycle aborts incomplete multipart uploads.
- Provider share uses a purpose-bound snapshot/checksum/expiry, not direct object-key authority.

1.4 Explicit PR sequence

Order	ID	Title	Repository	Dependencies	Gate	Local preparation	Merge readiness
1	P09-01	Define document lifecycle, authorization, and retention contract	app	P00-01, P02-01	A2	Technical-decision preparation only; implementation waits on named dependencies	Blocked pending PR dependencies P00-01, P02-01; Gate A0 active and verified; Luke review/final founder approval
2	P09-02	Provision private encrypted document and quarantine storage	infra	P09-01, P13-02	A2	Not ready; named PR, decision or programme-acceptance prerequisites remain	Blocked pending PR dependencies P09-01, P13-02; technical decisions/controls D-DOC-02; Gate A0 active and verified; Luke review/final founder approval
3	P09-03	Implement resilient document upload, scan, and download	app	P09-02, P02-03	A2	Not ready; named PR, decision or programme-acceptance prerequisites remain	Blocked pending PR dependencies P09-02, P02-03; technical decisions/controls D-DOC-01, D-DOC-02; Gate A0 active and verified; Luke review/final founder approval

Order	ID	Title	Repository	Dependencies	Gate	Local preparation	Merge readiness
4	P09-04	Ship phase-1 case progress and metadata-only request/review	app	P03-03, P03-05, P07-04, P09-01, P11-03	A2	Not ready; named PR, decision or programme-acceptance prerequisites remain	Blocked pending PR dependencies P03-03, P03-05, P07-04, P09-01, P11-03; Gate A0 active and verified; Luke review/final founder approval
5	P09-05	Implement consent-scoped provider handoff snapshots and operations	app	P04-02, P09-06, P10-02	A2	Not ready; named PR, decision or programme-acceptance prerequisites remain	Blocked pending PR dependencies P04-02, P09-06, P10-02; technical decisions/controls D-PROV-01; Gate A0 active and verified; Luke review/final founder approval
6	P09-06	Integrate content-bearing document versions into participant surfaces	app	P09-03, P09-04	A2	Not ready; named PR, decision or programme-acceptance prerequisites remain	Blocked pending PR dependencies P09-03, P09-04; Gate A0 active and verified; Luke review/final founder approval

1.4.1 P09-01 - Define document lifecycle, authorization, and retention contract

Field	Plan
Repository / base	`app` (`main`)
Gate / size	A2 / Medium
Local preparation status	Technical-decision preparation only; implementation waits on named dependencies
Merge readiness	Blocked pending PR dependencies P00-01, P02-01; Gate A0 active and verified; Luke review/final founder approval
Technical-decision owner	D-DOC-01: Alan - later download/recovery mechanism; privacy/legal validation; D-DOC-02: Alan - later scanner/quarantine mechanism; D-PHI-01: Alan - technical evidence; qualified external reviewers - control approval
Dependencies	P00-01, P02-01
Blocking decisions/checkpoints	None beyond dependencies and plan approval
Source / salvage	Current metadata-only documents.py, Wave 2@5b63e3a, provider branch

1.4.1.1 Objective Record separate metadata-requirement/work-item and content-bearing document/version state machines, the authorization matrix, object-key independence, retention/deletion/replacement rules, and failure recovery before implementation.

1.4.1.2 Scope

- Requirement/readiness/work-item states that never imply content approval
- Document/version/upload/scan/available/review/replace/delete states
- Owner/person/case-side/case authorization and staff capabilities
- Size/type/checksum and structured metadata policy
- Presigned versus proxied download decision
- Orphan/retention jobs

1.4.1.3 Explicit non-goals

- No bucket or application code

1.4.1.4 Expected files or modules

- `docs/adr/ADR-00x-durable-documents.md`
- `docs/agents/documents.md`
- `docs/security/document-threat-model.md`

1.4.1.5 Change map

Area	Planned change
Schema/model	None in this PR; any later schema change stays in its named migration PR.
API/routes	No public API/route contract change.

Area	Planned change
UI/product surface	No visible participant/operator UI change.
Infrastructure/workflow	No cloud/infrastructure resource or workflow change.
Migration/backfill	No migration or backfill.
Security/privacy	Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases.
Architecture/docs/config	Decision and threat model only.

1.4.1.6 Tests and validation

Objective tests:

- Threat-model abuse cases
- metadata-versus-content transition table review
- retention/legal-hold walkthrough
- PHI-bearing free-text negative cases

Local validation:

- `python -m unittest discover -s tests/python`
- Run the focused test module(s) named above against SQLite and PostgreSQL where applicable.

Cloud validation: run only through Gate **A2** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.1.7 Diagnostics and observability

Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

1.4.1.8 Rollout

Deploy behind the narrowest practical feature/config gate, verify the named synthetic flow and diagnostics on a known revision, then widen only at the associated programme gate.

1.4.1.9 Rollback or forward repair

Disable the feature or return to the prior compatible image; retain append-only audit/ledger history and repair with a new event/revision rather than destructive mutation.

1.4.1.10 Dependencies and parallel work

Hard dependencies: P00-01, P02-01. Parallel opportunities: P09-03, P09-05, P09-06

1.4.1.11 Objective acceptance criteria

- ☐ Record separate metadata-requirement/work-item and content-bearing document/version state machines, the authorization matrix, object-key independence, retention/deletion/replacement rules, and failure recovery before implementation.
- ☐ Every listed objective test passes locally and at the required gate where applicable.

- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ The planning record has matching dependency, local-preparation, merge-readiness, ownership, gate and disposition fields.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.1.12 Ownership and review

Role	Recommendation
Work-package DRI	Alan
Primary implementer	Alan (proposed; pending Alan review)
Technical-decision owner	D-DOC-01: Alan - later download/recovery mechanism; privacy/legal validation; D-DOC-02: Alan - later scanner/quarantine mechanism; D-PHI-01: Alan - technical evidence; qualified external reviewers - control approval
Reviewer	Luke
Final approver	Luke
PR-level ownership exception	None
Required expertise	application security, S3/KMS, privacy
Higher-capability review	Mandatory before merge

1.4.2 P09-02 - Provision private encrypted document and quarantine storage

Field	Plan
Repository / base	`infra` (`main`)
Gate / size	A2 / Large
Local preparation status	Not ready; named PR, decision or programme-acceptance prerequisites remain
Merge readiness	Blocked pending PR dependencies P09-01, P13-02; technical decisions/controls D-DOC-02; Gate A0 active and verified; Luke review/final founder approval
Technical-decision owner	D-DOC-02: Alan - later scanner/quarantine mechanism; D-PHI-01: Alan - technical evidence; qualified external reviewers - control approval
Dependencies	P09-01, P13-02
Blocking decisions/checkpoints	D-DOC-02
Source / salvage	Existing infra platform stack patterns

1.4.2.1 Objective Provision dev/private document buckets, KMS policy, block-public-access, lifecycle/quarantine events, least-privilege task roles, and audit logging behind PHI/billable guardrails.

1.4.2.2 Scope

- Private primary/quarantine storage

- KMS and task-role policy
- Lifecycle/orphan signals
- No public ACL/policy

1.4.2.3 Explicit non-goals

- No production/PHI activation
- No application upload

1.4.2.4 Expected files or modules

- `lib/stacks/platform-stack.ts`
- `lib/constructs/document-storage.ts`
- `test/document-storage.test.ts`
- `docs/agents/platform-stack.md`

1.4.2.5 Change map

Area	Planned change
Schema/model	None in this PR; any later schema change stays in its named migration PR.
API/routes	No public API/route contract change.
UI/product surface	No visible participant/operator UI change.
Infrastructure/workflow	CDK resources and SSM outputs in dev, desired counts unchanged by default.
Migration/backfill	No migration or backfill.
Security/privacy	Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases.
Architecture/docs/config	Document the contract, version pins and safe partial-merge behavior.

1.4.2.6 Tests and validation Objective tests:

- CDK assertions
- IAM negative cases
- public-access-block
- encryption/lifecycle/event contract

Local validation:

- `npm test`
- `npm run build`
- `Synthesize the affected CDK stack with billable/live changes disabled.`

Cloud validation: run only through Gate **A2** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.2.7 Diagnostics and observability Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

1.4.2.8 Rollout Synthesize and review first; deploy only through the guarded dev workflow with billable/desired-count defaults unchanged, exact revision recorded, and explicit confirmation outside this planning task.

1.4.2.9 Rollback or forward repair Return to the prior reviewed stack/task definition when compatible; otherwise keep resources fail-closed and forward-repair under the runbook. Never delete data-bearing resources as an automatic rollback.

1.4.2.10 Dependencies and parallel work Hard dependencies: P09-01, P13-02. Parallel opportunities: P09-04, P09-05, P09-06

1.4.2.11 Objective acceptance criteria

- ☐ Provision dev/private document buckets, KMS policy, block-public-access, lifecycle/quarantine events, least-privilege task roles, and audit logging behind PHI/billable guardrails.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ The planning record has matching dependency, local-preparation, merge-readiness, ownership, gate and disposition fields.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.2.12 Ownership and review

Role	Recommendation
Work-package DRI	Alan
Primary implementer	Alan (proposed; pending Alan review)
Technical-decision owner	D-DOC-02: Alan - later scanner/quarantine mechanism; D-PHI-01: Alan - technical evidence; qualified external reviewers - control approval
Reviewer	Luke
Final approver	Luke
PR-level ownership exception	None
Required expertise	AWS S3, KMS/IAM, CDK, security
Higher-capability review	Mandatory before merge

1.4.3 P09-03 - Implement resilient document upload, scan, and download

Field	Plan
Repository / base	`app` (`main`)
Gate / size	A2 / Exceptional
Local preparation status	Not ready; named PR, decision or programme-acceptance prerequisites remain
Merge readiness	Blocked pending PR dependencies P09-02, P02-03; technical decisions/controls D-DOC-01, D-DOC-02; Gate A0 active and verified; Luke review/final founder approval
Technical-decision owner	D-DOC-01: Alan - later download/recovery mechanism; privacy/legal validation; D-DOC-02: Alan - later scanner/quarantine mechanism
Dependencies	P09-02, P02-03
Blocking decisions/checkpoints	D-DOC-01, D-DOC-02
Source / salvage	Current metadata scaffold

1.4.3.1 Objective Implement multipart-safe upload intent/finalize, checksum/type/size validation, quarantine/scan transitions, authorized download, replacement, deletion, and task-recovery behavior.

1.4.3.2 Scope

- Opaque object keys and sanitized display names
- Durable upload states
- Malware/quarantine integration
- Presigned/proxy path per ADR
- Audit events

1.4.3.3 Explicit non-goals

- No public object URL
- No provider share by key

1.4.3.4 Expected files or modules

- `app/documents/service.py`
- `app/documents/storage.py`
- `app/routes/documents.py`
- `app/jobs/document_recovery.py`
- `tests/python/test_documents_e2e.py`

1.4.3.5 Change map

Area	Planned change
Schema/model	Versioned document/upload/scan/object metadata.
API/routes	Intent/finalize/status/download/replace/delete commands.
UI/product surface	No visible participant/operator UI change.

Area	Planned change
Infrastructure/workflow	No cloud/infrastructure resource or workflow change.
Migration/backfill	No migration or backfill.
Security/privacy	Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases.
Architecture/docs/config	Document the contract, version pins and safe partial-merge behavior.

1.4.3.6 Tests and validation Objective tests:

- Oversize/type spoof
- checksum mismatch
- scan fail/timeout
- ECS task replacement
- orphan cleanup
- authorization

Local validation:

- `python -m unittest discover -s tests/python`
- Run the focused test module(s) named above against SQLite and PostgreSQL where applicable.

Cloud validation: run only through Gate **A2** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.3.7 Diagnostics and observability Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

1.4.3.8 Rollout Ship expand-only and dark by default; run the one-off migrator, verify readiness/old-revision compatibility, then enable writers/readers in a later compatible step.

1.4.3.9 Rollback or forward repair Prefer application rollback within the expand/contract window and a new forward-repair migration. An irreversible schema reversal requires its own approval and backup evidence.

1.4.3.10 Dependencies and parallel work Hard dependencies: P09-02, P02-03. Parallel opportunities: P09-01, P09-04, P09-05

1.4.3.11 Objective acceptance criteria

- ☐ Implement multipart-safe upload intent/finalize, checksum/type/size validation, quarantine/scan transitions, authorized download, replacement, deletion, and task-recovery behavior.
- ☐ Every listed objective test passes locally and at the required gate where applicable.

- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ The planning record has matching dependency, local-preparation, merge-readiness, ownership, gate and disposition fields.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.3.12 Ownership and review

Role	Recommendation
Work-package DRI	Alan
Primary implementer	Alan (proposed; pending Alan review)
Technical-decision owner	D-DOC-01: Alan - later download/recovery mechanism; privacy/legal validation; D-DOC-02: Alan - later scanner/quarantine mechanism
Reviewer	Luke
Final approver	Luke
PR-level ownership exception	None
Required expertise	S3, secure uploads, background jobs, authorization
Higher-capability review	Mandatory before merge

1.4.4 P09-04 - Ship phase-1 case progress and metadata-only request/review

Field	Plan
Repository / base	`app` (`main`)
Gate / size	A2 / Exceptional
Local preparation status	Not ready; named PR, decision or programme-acceptance prerequisites remain
Merge readiness	Blocked pending PR dependencies P03-03, P03-05, P07-04, P09-01, P11-03; Gate A0 active and verified; Luke review/final founder approval
Technical-decision owner	None; implement the settled founder constraints and approved contracts
Dependencies	P03-03, P03-05, P07-04, P09-01, P11-03
Blocking decisions/checkpoints	None beyond dependencies and plan approval
Source / salvage	PR #122 case projection behavior/tests, Wave 2@5b63e3a semantics/tests; implementation superseded, PR #124 presentation evidence

1.4.4.1 Objective Expose projection-driven phase-1 cluster progress and a revision-bound metadata requirement/readiness/reviewer-work workflow without creating or approving a document object.

1.4.4.2 Scope

- Versioned phase-1 workflow/request definitions
- Projection-issued action capabilities for active/waiting/attention/paused/done states

- Person versus case-side ownership
- Atomic submission plus durable case work item
- Revision-bound/idempotent staff decision plus audit
- Exact phase-1 route exposure

1.4.4.3 Explicit non-goals

- No file bytes, storage URI, upload, scan, download or artifact approval
- No caller-supplied role/lens authority
- No client-owned state transition
- No operator/provider ambient access

1.4.4.4 Expected files or modules

- `migrations/versions/*_case_requirements.py`
- `app/case_home.py`
- `app/case_journey.py`
- `app/case_requirements.py`
- `app/routes/case.py`
- `app/routes/operator_case_work.py`
- `app/templates/case/`
- `tests/python/test_case_requirements.py`

1.4.4.5 Change map

Area	Planned change
Schema/model	Requirement submissions and durable typed work items use constrained case/org/owner anchors and immutable expected revisions.
API/routes	No public API/route contract change.
UI/product surface	Participant progress and readiness surfaces remain projection-driven.
Infrastructure/workflow	No cloud/infrastructure resource or workflow change.
Migration/backfill	Apply through the named versioned migration; no ad-hoc startup DDL. Backfill is none unless explicitly listed in scope.
Security/privacy	Subject-derived participant capabilities and explicit organization-scoped staff capability gate every read/command.
Architecture/docs/config	Document the contract, version pins and safe partial-merge behavior.

1.4.4.6 Tests and validation Objective tests:

- IP/GC paired lenses
- viewer/nonmember/spoofed-role denial
- restart durability
- stale work item cannot approve resubmission
- atomic submission/task and review/audit rollback
- wrong case/org and unsupported type retained

- paused/done action suppression
- later-phase 404
- mobile/no-JS/reduced-motion

Local validation:

- `python -m unittest discover -s tests/python`
- Run the focused test module(s) named above against SQLite and PostgreSQL where applicable.

Cloud validation: run only through Gate **A2** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.4.7 Diagnostics and observability Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

1.4.4.8 Rollout Ship expand-only and dark by default; run the one-off migrator, verify readiness/old-revision compatibility, then enable writers/readers in a later compatible step.

1.4.4.9 Rollback or forward repair Prefer application rollback within the expand/contract window and a new forward-repair migration. An irreversible schema reversal requires its own approval and backup evidence.

1.4.4.10 Dependencies and parallel work Hard dependencies: P03-03, P03-05, P07-04, P09-01, P11-03. Parallel opportunities: P09-02, P09-03, P09-05

1.4.4.11 Objective acceptance criteria

- ☐ Expose projection-driven phase-1 cluster progress and a revision-bound metadata requirement/readiness/reviewer-work workflow without creating or approving a document object.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ The planning record has matching dependency, local-preparation, merge-readiness, ownership, gate and disposition fields.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.4.12 Ownership and review

Role	Recommendation
Work-package DRI	Alan
Primary implementer	Alan (proposed; pending Alan review)

Role	Recommendation
Technical-decision owner	None; implement the settled founder constraints and approved contracts
Reviewer	Luke
Final approver	Luke
PR-level ownership exception	None
Required expertise	FastAPI/Jinja, accessibility, authorization, PostgreSQL transactions, state projection
Higher-capability review	Mandatory before merge

1.4.5 P09-05 - Implement consent-scoped provider handoff snapshots and operations

Field	Plan
Repository / base	`app` (`main`)
Gate / size	A2 / Exceptional
Local preparation status	Not ready; named PR, decision or programme-acceptance prerequisites remain
Merge readiness	Blocked pending PR dependencies P04-02, P09-06, P10-02; technical decisions/controls D-PROV-01; Gate A0 active and verified; Luke review/final founder approval
Technical-decision owner	D-PROV-01: Alan - later provider-packet mechanism; privacy/provider validation; D-PHI-01: Alan - technical evidence; qualified external reviewers - control approval
Dependencies	P04-02, P09-06, P10-02
Blocking decisions/checkpoints	D-PROV-01
Source / salvage	Protected provider-exchange worktree: selective port only after provenance fix

1.4.5.1 Objective Create purpose-bound, reviewed, checksummed provider packets from explicitly allowed facts/documents and operate send/confirm/revoke/reroute without ambient provider access.

1.4.5.2 Scope

- Packet revisions/snapshots/checksums
- Consent, recipient, purpose, expiry
- Operator route review and transmission outcomes
- Inbound evidence becomes proposal

1.4.5.3 Explicit non-goals

- No raw private/provisional bulk projection
- No provider truth without review

1.4.5.4 Expected files or modules

- `app/provider_handoffs.py`
- `app/storage/handoffs.py`
- `app/routes/operator_handoffs.py`
- `app/templates/internal/handoffs/`
- `tests/python/test_provider_handoffs.py`

1.4.5.5 Change map

Area	Planned change
Schema/model	Handoff/packet/snapshot/transmission/evidence ledgers under migrations.
API/routes	No public API/route contract change.
UI/product surface	Case-scoped operator queue and GC review.
Infrastructure/workflow	No cloud/infrastructure resource or workflow change.
Migration/backfill	No migration or backfill.
Security/privacy	Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases.
Architecture/docs/config	Document the contract, version pins and safe partial-merge behavior.

1.4.5.6 Tests and validation Objective tests:

- Purpose allowlist
- revoked consent
- stale route
- snapshot immutability
- delivery retry
- private/provisional exclusion

Local validation:

- `python -m unittest discover -s tests/python`
- Run the focused test module(s) named above against SQLite and PostgreSQL where applicable.

Cloud validation: run only through Gate **A2** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.5.7 Diagnostics and observability Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

1.4.5.8 Rollout Ship expand-only and dark by default; run the one-off migrator, verify readiness/old-revision compatibility, then enable writers/readers in a later compatible step.

1.4.5.9 Rollback or forward repair Prefer application rollback within the expand/contract window and a new forward-repair migration. An irreversible schema reversal requires its own approval and backup evidence.

1.4.5.10 Dependencies and parallel work Hard dependencies: P04-02, P09-06, P10-02. Parallel opportunities: P09-01, P09-02, P09-03, P09-04

1.4.5.11 Objective acceptance criteria

- ☐ Create purpose-bound, reviewed, checksummed provider packets from explicitly allowed facts/documents and operate send/confirm/revoke/reroute without ambient provider access.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ The planning record has matching dependency, local-preparation, merge-readiness, ownership, gate and disposition fields.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.5.12 Ownership and review

Role	Recommendation
Work-package DRI	Alan
Primary implementer	Alan (proposed; pending Alan review)
Technical-decision owner	D-PROV-01: Alan - later provider-packet mechanism; privacy/provider validation; D-PHI-01: Alan - technical evidence; qualified external reviewers - control approval
Reviewer	Luke
Final approver	Luke
PR-level ownership exception	None
Required expertise	provider workflows, privacy, document security, operations
Higher-capability review	Mandatory before merge

1.4.6 P09-06 - Integrate content-bearing document versions into participant surfaces

Field	Plan
Repository / base	`app` (`main`)
Gate / size	A2 / Large
Local preparation status	Not ready; named PR, decision or programme-acceptance prerequisites remain
Merge readiness	Blocked pending PR dependencies P09-03, P09-04; Gate A0 active and verified; Luke review/final founder approval
Technical-decision owner	D-DOC-01: Alan - later download/recovery mechanism; privacy/legal validation; D-DOC-02: Alan - later scanner/quarantine mechanism; D-PHI-01: Alan - technical evidence; qualified external reviewers - control approval
Dependencies	P09-03, P09-04
Blocking decisions/checkpoints	None beyond dependencies and plan approval
Source / salvage	P09-03 durable pipeline, Wave 2 metadata UI as contrast evidence, PR #122 participant case surfaces

1.4.6.1 Objective

Connect metadata requirements to upload intents, quarantined/scanned content versions, replacement and authorized download without collapsing requirement state into object state.

1.4.6.2 Scope

- Requirement-to-upload intent linkage
- Quarantine/scan/available and replacement projections
- Owner/role-scoped upload and download controls
- Content-version audit and restart recovery
- Fail-closed partial merge when content pipeline is unavailable

1.4.6.3 Explicit non-goals

- No metadata endpoint accepts bytes
- No readiness marker becomes document approval
- No provider share by object key
- No PHI before B2

1.4.6.4 Expected files or modules

- `app/documents/participant_service.py`
- `app/routes/case_documents.py`
- `app/templates/case/documents/`
- `tests/python/test_case_document_integration.py`

1.4.6.5 Change map

Area	Planned change
Schema/model	None in this PR; any later schema change stays in its named migration PR.
API/routes	Participant document commands join requirement IDs to immutable content versions.
UI/product surface	Content controls appear only when the content capability and approved gate state are present.
Infrastructure/workflow	No cloud/infrastructure resource or workflow change.
Migration/backfill	No migration or backfill.
Security/privacy	Authorization is re-evaluated at intent, finalize, status and download.
Architecture/docs/config	Document the contract, version pins and safe partial-merge behavior.

1.4.6.6 Tests and validation

Objective tests:

- Metadata endpoint rejects bytes
- owner/role/viewer denial
- quarantine/scan/replacement

- restart recovery
- multi-IP isolation
- feature-disabled/partial-merge failure
- mobile/no-JS

Local validation:

- `python -m unittest discover -s tests/python`
- Run the focused test module(s) named above against SQLite and PostgreSQL where applicable.

Cloud validation: run only through Gate **A2** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.6.7 Diagnostics and observability Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

1.4.6.8 Rollout Deploy behind the narrowest practical feature/config gate, verify the named synthetic flow and diagnostics on a known revision, then widen only at the associated programme gate.

1.4.6.9 Rollback or forward repair Disable the feature or return to the prior compatible image; retain append-only audit/ledger history and repair with a new event/revision rather than destructive mutation.

1.4.6.10 Dependencies and parallel work Hard dependencies: P09-03, P09-04. Parallel opportunities: P09-01, P09-02

1.4.6.11 Objective acceptance criteria

- ☐ Connect metadata requirements to upload intents, quarantined/scanned content versions, replacement and authorized download without collapsing requirement state into object state.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ The planning record has matching dependency, local-preparation, merge-readiness, ownership, gate and disposition fields.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.6.12 Ownership and review

Role	Recommendation
Work-package DRI	Alan
Primary implementer	Alan (proposed; pending Alan review)

Role	Recommendation
Technical-decision owner	D-DOC-01: Alan - later download/recovery mechanism; privacy/legal validation; D-DOC-02: Alan - later scanner/quarantine mechanism; D-PHI-01: Alan - technical evidence; qualified external reviewers - control approval
Reviewer	Luke
Final approver	Luke
PR-level ownership exception	None
Required expertise	secure documents, FastAPI/Jinja, authorization, resilient workflows
Higher-capability review	Mandatory before merge

1.5 Cross-repository coordination

Repository	Authority after merge
`app`	routing, validation, authorization, participant/case/workflow truth, PHI policy and commercial domain
`infra`	AWS resources, IAM/KMS/network/deployment/backup/audit contracts

Merge order inside this package: `P09-01` → `P09-02` → `P09-03` → `P09-04` → `P09-06` → `P09-05`.

Handoff rule: producer contract/version must merge and be pinned before its consumer enables the feature. During a partial merge, consumers fail closed or retain the last approved version; they do not fabricate data or silently broaden access.

Compatibility window: keep prior readers/writers and rollback image usable through the named gate; contract/migration PRs document the exact removal point.

1.6 Test and acceptance matrix

Test dimension	Method	Objective result
Happy path	Unauthorized object access; Oversize/type/spoof; Scan failure/quarantine; Partial upload/task loss; Snapshot immutability/revocation; Mobile documents	Expected state/event/UI and named evidence are produced once.
Authorization failure	Wrong/no subject, role, membership, purpose or consent	403/404 as appropriate; no write or data leak; audit safe failure.
Role differences	Separate IP, GC, operator, provider/service identities	Only the approved lens/projection/actions appear.
Retries/duplicates	Repeat same canonical request/event	Original result returned; no duplicate membership/case/invoice/document/event.

Test dimension	Method	Objective result
Concurrency	Two writers/claimants/migrators/workers	One valid transition; loser receives deterministic stale/conflict response.
Stale state	Old revision/config/terms/token/artifact	Fail closed or approved compatibility behavior; never silent coercion.
Malformed input	Boundary, encoding, size, enum, redirect and identifier corpus	Validation before side effects; safe error.
Unavailable dependency	Database, intelligence, processor, S3/scanner or auth unavailable	Explicit degraded/blocked behavior; no hallucinated success.
Partial failure	Crash between external effect, DB transaction and outbox	Retry/forward repair converges from durable evidence.
Logout/login/resume	Session expires/restarts mid-flow	Return to authorized current state; no query/link authority.
Mobile/accessibility	320/375/768 widths, keyboard, focus, reduced motion	Core task completes with truthful state and no clipped controls.
Synthetic cloud	Known dev revision and synthetic identities/data	Gate artifact records SHA, dependency status, audit and cleanup.
Audit/observability	Inspect events/metrics/logs	Versions, actor/authority, correlation and reason present; no sensitive payload.

1.7 Risks and decisions

Founder outcomes, Alan's remaining technical ownership and external activation dependencies are recorded separately so a final policy is never mistaken for an active control.

ID	Status	Classification	Remaining owner	Affected / latest	Programme effect
D-AUTH-03	Resolved by reconciliation	Reconciliation settled	Alan - implementation	P03-02, P03-03, P03-05, P04-01, P04-02, P09-04, P13-05; Resolved 2026-07-12	No longer blocks the reconciled access/workspace PR sequence.
D-DATA-01	Founder decision final; implementation evidence pending	Luke decides product/privacy outcome	Alan - implementation	P04-02, P06-02, P06-03, P07-03, P07-04, P09-05, P10-01, P10-02; Before P04-02	Founder ambiguity is removed across WP04, WP06, WP07, WP09 and WP10; A1 still requires the technical denial evidence.
D-COM-04	Founder decision final; implementation evidence pending	Luke decides commercial/product outcome	Alan - implementation	P07-02, P07-03, P07-04, P08-03, P09-04; Before P07-02	P07-02 through P09-04 may proceed under the settled semantics.

ID	Status	Classification	Remaining owner	Affected / latest	Programme effect
D-DOC-01	Founder default final; Alan later; external validation before B1/B2	Luke sets policy; Alan decides implementation later	Alan - later before P09-03; privacy/legal - validation	P09-01, P09-03, P09-06; Before P09-03	P09-01 ADR work may proceed; P09-03/P09-06 and real-content activation wait for Alan's delivery choice and evidence.
D-DOC-02	Founder constraints final; Alan later	Luke sets constraints; Alan decides later	Alan - later before P09-02	P09-01, P09-02, P09-03, P09-06; Before P09-02	P09-01 contract work may proceed; P09-02/P09-03/P09-06 wait for Alan's technical selection and evidence.
D-PROV-01	Founder decision final; Alan later	Luke decides product/privacy outcome; Alan implements later	Alan - later before P09-05	P09-05; Before P09-05	Synthetic provider-snapshot design may proceed; P09-05 completion and real handoff require Alan's evidence and later external review.
D-PHI-01	Founder beta scope final; externally gated	Luke decides beta scope; external evidence required	Alan - B1/B2 evidence; external reviewers - approval	P09-01, P09-02, P09-05, P09-06, P13-05, P13-06, P13-07; Before B1 for PII scope; before B2 for PHI	B1 remains blocked until the limited PII control bundle is accepted; real documents/provider packets and all PHI remain blocked until B2.

1.7.1 D-AUTH-03 - Identity, participation and access authorization contract

Field	Recorded decision or requirement
Decision state	Final
Founder outcome	Identity, participation, access grants, ownership and operation authorization remain separate; participation or lens alone never authorizes.

Field	Recorded decision or requirement
Founder constraints	Subject-derived authorization context; Application and RLS policy parity; Default-deny cross-resource access
What remains for Alan	Encode the settled contract in application services and RLS
Evidence required	Participation-without-grant and grant-without-capability denials; Application/RLS parity tests
Approval rule	No further founder decision unless the boundary changes.
External dependencies	None
Affected PRs / latest point	P03-02, P03-03, P03-05, P04-01, P04-02, P09-04, P13-05; Resolved 2026-07-12
Programme effect	No longer blocks the reconciled access/workspace PR sequence.
Independent recommendation	Identity binds principal to person; participation records domain relationship; grants carry resource-scoped capabilities; application and RLS consume a subject-derived context plus ownership and purpose. Participation/lens alone never authorizes.

1.7.2 D-DATA-01 - IP-GC field projection allowlist

Field	Recorded decision or requirement
Decision state	Final
Founder outcome	Use need-to-know sharing. Shared journey status and agreed relationship/outreach/logistics may cross roles; private IP notes, unconfirmed assertions and GC medical, reproductive, insurance, identity or wellbeing answers do not cross automatically. Provider packets require preview, consent and appropriate verification.
Founder constraints	Default-deny field-and-purpose allowlists; Source-labelled corrections; Named-purpose provider projection only
What remains for Alan	Define explicit field/purpose allowlists in code and projection contracts; Implement cross-role and provider negative tests
Evidence required	Cross-role denial matrix; Provider projection allowlist tests; Correction/source-label evidence
Approval rule	Luke approval is required for a broader sharing policy, not for compliant implementation detail.
External dependencies	None
Affected PRs / latest point	P04-02, P06-02, P06-03, P07-03, P07-04, P09-05, P10-01, P10-02; Before P04-02
Programme effect	Founder ambiguity is removed across WP04, WP06, WP07, WP09 and WP10; A1 still requires the technical denial evidence.

Field	Recorded decision or requirement
Independent recommendation	Default deny; expose only explicit purpose-limited projections. Class 1/2 and class 4 never automatically cross roles.

1.7.3 D-COM-04 - Enrollment funding and activation evidence

Field	Recorded decision or requirement
Decision state	Final
Founder outcome	Use two-step commitment: settled $750 plus current accepted terms proves commercial enrollment, but payment alone never promotes. Exactly one enrollment-pending case follows explicit IP promotion and authenticated GC consent. The $1,630 activation tranche is earned only after defined IP/GC onboarding and screening coordination has begun; it never implies medical clearance.
Founder constraints	Redirects/webhooks never promote; Typed promotion event only; Source-labelled facts and explicit evidence checklist
What remains for Alan	Define typed events, activation checklist, idempotency and audit mechanics
Evidence required	Duplicate, replay, partial-failure, promotion and activation evidence tests
Approval rule	Luke approves any change to commercial enrollment or activation semantics.
External dependencies	None
Affected PRs / latest point	P07-02, P07-03, P07-04, P08-03, P09-04; Before P07-02
Programme effect	P07-02 through P09-04 may proceed under the settled semantics.
Independent recommendation	Funding confirmation is durable ledger evidence; promotion uses the sole typed authorization event; activation requires an explicit evidence checklist, actor and audit event.

1.7.4 D-DOC-01 - Document retention, deletion, replacement and download mode

Field	Recorded decision or requirement
Decision state	Final founder default; externally dependent activation

Field	Recorded decision or requirement
Founder outcome	Retain clean active-case documents while active plus two years after close; signed consents, payment/access audits and deletion tombstones for seven years; failed/quarantine orphans seven days; superseded content 90 days unless required; honor valid deletion within 30 days subject to legal hold. Downloads require fresh authorization and links expire within five minutes.
Founder constraints	Never public; Never withheld for non-payment; Legal hold and deletion remain auditable
What remains for Alan	Choose proxy versus presigned delivery by class; Implement hold, deletion, tombstone, retry and authorization behavior
Evidence required	Fresh-authorization and five-minute-link tests; Retention/hold/deletion exercise; Privacy/legal approval before real content
Approval rule	Luke accepts live policy after privacy/legal review.
External dependencies	Privacy/legal validation before B1/B2 real-content use
Affected PRs / latest point	P09-01, P09-03, P09-06; Before P09-03
Programme effect	P09-01 ADR work may proceed; P09-03/P09-06 and real-content activation wait for Alan's delivery choice and evidence.
Independent recommendation	Purpose/role authorization independent of key; short-lived downloads; deletion tombstone/audit; legal/privacy review.

1.7.5 D-DOC-02 - Document limits and malware/quarantine provider

Field	Recorded decision or requirement
Decision state	Final founder constraints
Founder outcome	Allow PDF, JPEG, PNG and non-macro DOCX up to 50 MiB. Reject spoofed, macro-enabled and archive-like input; quarantine until clean; treat password-protected, skipped, error and timeout results as unavailable.
Founder constraints	Normal scan target no more than two minutes; Transient retries no more than 15 minutes; $50/month beta scanning ceiling with alerts; Synthetic only at A2 and no PHI before B2
What remains for Alan	Choose the AWS-native scanner, queue, retry, timeout, recovery and cost-control mechanisms
Evidence required	Type/sniffing/spoof tests; Quarantine, error, timeout and retry tests; Cost estimate and alerts
Approval rule	Luke approval is required if the solution exceeds the cost or safety constraints.
External dependencies	None
Affected PRs / latest point	P09-01, P09-02, P09-03, P09-06; Before P09-02

Field	Recorded decision or requirement
Programme effect	P09-01 contract work may proceed; P09-02/P09-03/P09-06 wait for Alan's technical selection and evidence.
Independent recommendation	Narrow allowlist, checksum and content sniffing; unavailable scanner remains quarantined.

1.7.6 D-PROV-01 - Provider handoff purposes and field allowlists

Field	Recorded decision or requirement
Decision state	Final founder policy
Founder outcome	Provider handoff is a purpose-bound immutable snapshot for one verified recipient and named purpose, with participant preview/consent, clean documents and appropriately verified source-labelled facts. Unopened access expires after 14 days and can be revoked before access; downloaded copies cannot be recalled.
Founder constraints	No ambient provider case access in MVP; Audit every issue/open/download/revoke/expire event; Reissue after expiry
What remains for Alan	Choose recipient verification, snapshot checksum, expiry, revocation and audit mechanisms
Evidence required	Wrong-recipient, expiry, revoke-before-access, reissue and checksum tests
Approval rule	Luke approves broader recipient or ambient-access scope.
External dependencies	Privacy/provider review before real handoff
Affected PRs / latest point	P09-05; Before P09-05
Programme effect	Synthetic provider-snapshot design may proceed; P09-05 completion and real handoff require Alan's evidence and later external review.
Independent recommendation	Class 1/2 excluded; class 4 only if GC explicitly selects for recipient/purpose; class 5 evidence linked.

1.7.7 D-PHI-01 - PII/PHI boundary, vendors and control set

Field	Recorded decision or requirement
Decision state	Final founder scope; externally dependent activation

Field	Recorded decision or requirement
Founder outcome	B1 is an invitation-only US beta of at most five IP/GC pairs using names, verified account/contact data, relationship/outreach/logistics, consent versions, nonclinical progress, feedback and processor references only. Medical, reproductive-health, psychological, insurance-health and clinical-clearance data are prohibited; no real document bytes or provider packets; AI receives de-identified nonclinical context only.
Founder constraints	RLS/non-owner runtime and cross-tenant negative evidence; Access review plus incident and restore exercises; No PHI before B2
What remains for Alan	Implement inventory, cohort controls, RLS, cross-tenant denials, de-identification and prohibited-data tests
Evidence required	Five-pair cohort configuration; RLS/cross-tenant/de-identification/prohibited-data tests; External privacy/legal approval
Approval rule	Luke accepts B1 only after required evidence and external privacy/legal advice; B2 requires qualified external approval.
External dependencies	External privacy/legal approval before B1; Qualified external security/privacy/compliance/legal approval before B2
Affected PRs / latest point	P09-01, P09-02, P09-05, P09-06, P13-05, P13-06, P13-07; Before B1 for PII scope; before B2 for PHI
Programme effect	B1 remains blocked until the limited PII control bundle is accepted; real documents/provider packets and all PHI remain blocked until B2.
Independent recommendation	B1 remains PII-only and content controls stay synthetic; B2 requires formal external security/privacy/compliance evidence before any PHI content path is enabled.

Implementation risk	Owner	Treatment
PHI exposure	Alan	Mitigate through explicit tests, rollout and forward-repair evidence before the associated gate.
Malware	Alan	Mitigate through explicit tests, rollout and forward-repair evidence before the associated gate.
Orphaned objects	Alan	Mitigate through explicit tests, rollout and forward-repair evidence before the associated gate.
Stale provider packet	Alan	Mitigate through explicit tests, rollout and forward-repair evidence before the associated gate.
Dirty branch leakage	Alan	Mitigate through explicit tests, rollout and forward-repair evidence before the associated gate.

1.8 Existing-work salvage

Source	Head	Valuable content	Destination	Recommendation	Extraction status/safety
app#112	9605d88e31bd	Source-first 81-node/12-cluster surface map, participant-renderer boundaries, wave plan and cross-repo seams.	P09-04	Selective port, then supersede after extraction	Catalogued; content remains to be reconciled into replacement PR acceptance tests.
app#122	e85382150853	Case projection/lens surfaces, safe return_to, invitation TTL/CAS/self-member/one-GC constraints, transactional membership, fail-closed Learn, SQL-limited timeline, responsive/a11y tests and Python CI workflow.	P09-04	Selective-port behavior and tests; supersede as programme architecture	Complete at e853821: authoritative behavior/tests and selectively portable implementation are classified; superseded architecture and evidence-only claims are named.
app#124	84a5a847fea7	Consolidated Node 0 questionnaire/guide/surfaces, GC onboarding, participant case shell, invitation delegation, DS assets and large focused test suites as extraction evidence.	P09-04	Fully supersede as a merge unit; preserve selective concepts, copy, assets and tests as evidence	Complete at 84a5a84: all consolidated-review findings are dispositioned and assigned; no mergeable/cherry-pick unit is approved.

Source	Head	Valuable content	Destination	Recommendation	Extraction status/safety
feat/byos-journey-wave-2	5b63e3a7c364	Projection-driven phase-1 cluster presentation, exact route allowlisting, person-versus-case-side ownership intent, transactional submission/work-item and review/audit patterns, fail-closed item retention, approved Learn status selection and 36 focused tests.	P09-01, P09-04, P09-06	Preserve paused at the exact head; selectively port semantics/tests only after adaptation. Do not merge, cherry-pick, continue implementation or use its runtime schema directly.	Paused exact-head evidence; no direct merge
feature/provider-exchange-layer-v0	84a5a84	substantial uncommitted provider handoff/ops/document work	P09-01/P09-03/P09-05 after provenance/security review	Selective port from protected worktree	Do not stage, reset, stash, switch, commit, clean or overwrite.
main	current local	substantial uncommitted operator shell/design-system work	Not part of participant DS; review only if P09-05 operator UI needs approved internal recipes	Selective port from protected worktree	Preserve repo boundary and dirty worktree.

Package source inventory:

- Protected provider-exchange branch by selective port after review
- Current document metadata scaffold
- PR #122 case shell UX

1.9 Ownership recommendation

Alan owns implementation; Luke approves retention, provider purpose, and PHI boundary. External security/privacy and provider workflow review required.

PR	WP DRI	Primary implementer	Technical-decision owner	Reviewer	Final approver	Exception
P09-01	Alan	Alan (proposed)	D-DOC-01: Alan - later download/recovery mechanism; privacy/legal validation; D-DOC-02: Alan - later scanner/quarantine mechanism; D-PHI-01: Alan - technical evidence; qualified external reviewers - control approval	Luke	Luke	None
P09-02	Alan	Alan (proposed)	D-DOC-02: Alan - later scanner/quarantine mechanism; D-PHI-01: Alan - technical evidence; qualified external reviewers - control approval	Luke	Luke	None

PR	WP DRI	Primary implementer	Technical-decision owner	Reviewer	Final approver	Exception
P09-03	Alan	Alan (proposed)	D-DOC-01: Alan - later download/recovery mechanism; privacy/legal validation; D-DOC-02: Alan - later scanner/quarantine mechanism	Luke	Luke	None
P09-04	Alan	Alan (proposed)	None; implement the settled founder constraints and approved contracts	Luke	Luke	None
P09-05	Alan	Alan (proposed)	D-PROV-01: Alan - later provider-packet mechanism; privacy/provider validation; D-PHI-01: Alan - technical evidence; qualified external reviewers - control approval	Luke	Luke	None

PR	WP DRI	Primary implementer	Technical-decision owner	Reviewer	Final approver	Exception
P09-06	Alan	Alan (proposed)	D-DOC-01: Alan - later download/recovery mechanism; privacy/legal validation; D-DOC-02: Alan - later scanner/quarantine mechanism; D-PHI-01: Alan - technical evidence; qualified external reviewers - control approval	Luke	Luke	None

PR ownership inherits the proposed work-package split pending Alan's review. Named technical-decision ownership remains separate and never transfers implementation ownership across work packages; reciprocal and external review requirements remain intact.

1.10 Definition of done

- ☐ Every proposed PR is merged in dependency order or explicitly dispositioned, with its objective acceptance criteria and review record complete.
- ☐ All package blocking decisions are resolved by the named owner; no commercial/privacy/security value is guessed in code.
- ☐ Local, PostgreSQL, role/authorization, retry/concurrency, failure, mobile and synthetic-cloud evidence required by this package is attached.
- ☐ Cross-repository contracts and artifact/migration versions are pinned; partial-merge behavior is fail-closed or explicitly degraded.
- ☐ Observability is sufficient to identify revision, transition, dependency and safe failure without sensitive payloads.
- ☐ Existing PR/worktree value and reviewer findings are extracted before closure; no cleanup occurs without team confirmation.
- ☐ The associated programme gate is accepted by Luke and any required external reviewer; tests/deploy alone do not establish B1/B2.